

October 2024 | Vol. 4



Phishing Threat Trends Report

What's selling on the dark web, how one organization escaped an advanced persistent threat, and how you're being phished in 2024



IF AT FIRST YOU DON'T SUCCEED...

Creating successful cyberattacks is a hacker's job. So, in a twisted way, like the rest of us, if they're not good at their jobs, they won't get paid. This makes them highly motivated to get through defenses and socially engineer their targets.

In this edition, we'll look at the ways cybercriminals give each other a head start by selling phishing toolkits on the dark web, how they shift tactics during large-scale commodity attacks, the multiple steps they deploy during an advanced persistent threat campaign, and the different ways they impersonate brands and individuals. We'll also share key phishing statistics from 2024.

Unless otherwise cited, all statistics in this report have been generated using data from Egress Defend, an integrated cloud email security (ICES) solution that detects the full spectrum of advanced phishing attacks.

Our team would love to hear from you if you would like to discuss this report or find out how Egress can improve your email security.



Jack Chapman
SVP of Threat Intelligence, Egress

WHAT'S INSIDE

05 THE WEB OF DECEIT

The phishing toolkits for sale that contain AI-powered attacks and guarantees they'll get through Microsoft and SEG defenses

07 MASS-MAIL MAYHEM

How the rise in commodity phishing attacks is overwhelming security teams

11 PLAYING THE LONG GAME

The anatomy of advanced persistent threats and how cybercriminals failed to breach one organization

14 GUESS WHO?

We look at the most prolific phishing tactic in 2024: impersonation

19 RIDING THE WAVE OF A NEW AGE OF PHISHING THREATS

As AI is increasingly commoditized and attacks become more difficult to detect, we find ourselves at a turning point

How you're being phished in 2024

The most phished day of the year so far

June 10, 2024
12:37 pm

Most common time to receive a phishing email

28%

increase in phishing emails sent between April 1st – June 30th vs. January 1st – March 31st



44%

of phishing emails were sent from **compromised accounts**, helping them bypass authentication protocols

8% were from within the supply chain



45%

of phishing emails contained **hyperlink payloads**



23%

of phishing emails included **malicious attachments**

Top 5 legitimate platforms used to send phishing emails



Microsoft



Sender



salesforce



mailchimp



SendGrid

Most common URL shorteners used in phishing emails

urly

bitly

t.ly



20%

rely solely on social engineering



12%

contain a **QR code**

Top 5

Words



Financial terms

Symbols

Payment

1



Wire transfer

2



BACS

3



Credit

4



Purchase

5



Most impersonated brands ...



Adobe



Microsoft

CHASE



Meta



Employees only accurately report **29%** of phishing emails

*Data taken from Egress Defend between January 1st – August 31st 2024.

THE WEB OF DECEIT

The phishing toolkits for sale that contain AI-powered attacks and guarantees they'll get through Microsoft and SEG defenses.

In this edition, we look at large-scale commodity attacks, advanced persistent threats, and impersonation-based phishing. While individual cybercriminals can create these attacks themselves (either 'manually' writing emails and developing payloads, or by using Gen AI), these attacks or similar ones can also be bought on the dark web.

A constantly maturing ecosystem, the dark web has commoditized criminal activity, opening the door for less-skilled threat attackers to launch more sophisticated attacks than their own abilities would previously have allowed.

Many services offer a subscription-based model, enabling their 'customers' to benefit from enhancements and refresh their attacks at pace with payload blocklists. Depending on the services required, investment can be as little as \$30 per month, while top-end subscriptions cost an average of \$600 per month.

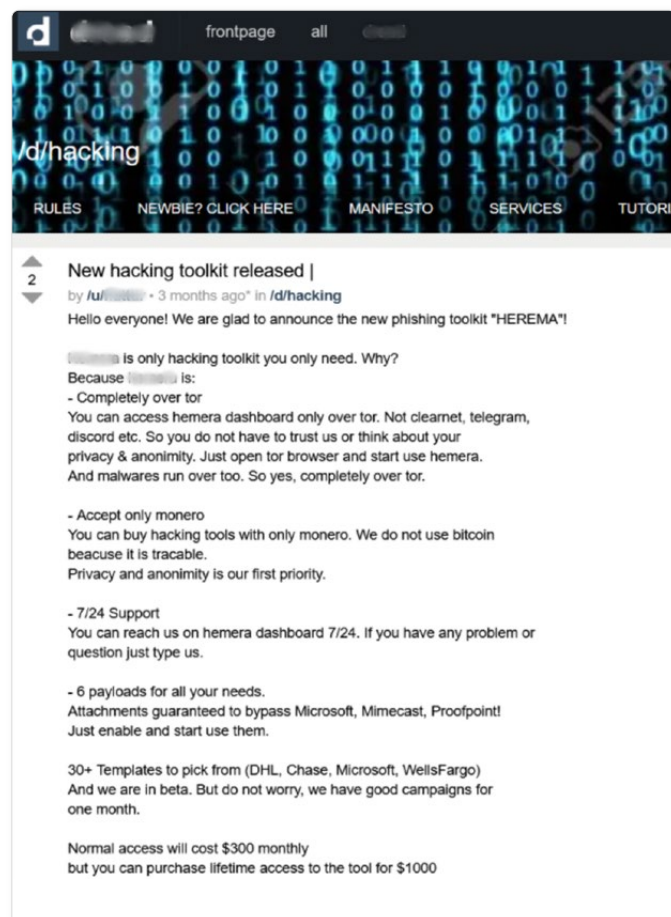
The phishing toolkits themselves offer a range of different techniques and tactics, including:

- **Templated attacks**, such as credential harvesting phishing emails impersonating large brands
- **Guarantees of deliverability** against Microsoft's native defenses and major secure email gateway (SEG) providers
- **Obfuscation techniques**
- **Polymorphic payloads**
- **Subscriptions to Gen AI applications** to produce attacks
- **OSINT toolkits**, containing collated data on specific targets

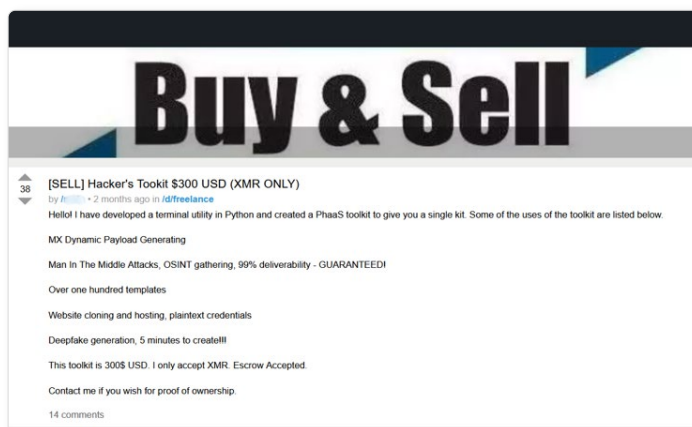
While the use of AI by cybercriminals has dominated the headlines since November 2021, in reality so far, access to these tools has required financial resources. However, this is changing fast. Of the toolkits our threat intelligence analysts examined, 74.8% referenced AI and 82.0% mentioned deepfakes.

Both the dark web marketplace sites and the sellers using them routinely offer assurance over the quality of their attacks and their own reputations. In fact, 46.0% of the toolkits examined came with moneyback and deliverability guarantees for bypassing Microsoft 365 and SEG detection, and most also offered 24/7 support, typically via Gpg4win, Telegram, Signal, and WhatsApp.

AD FOR PHISHING TOOLKIT, INCLUDING BRAND IMPERSONATION TEMPLATES AND GUARANTEED DELIVERY AGAINST MICROSOFT AND SEG DETECTION



TOOLKIT, INCLUDING DEEPPAKE GENERATION AVAILABLE FOR \$300



With cybercriminals purchasing phishing emails that are advertised as guaranteed to get through Microsoft and SEG detection, and the constantly 'revolving door' of these attacks, organizations must ensure they have advanced technologies layered into their email security stack to prevent employees from falling victim.

Of the toolkits our threat intelligence analysts examined, 74.8% referenced AI and 82.0% mentioned deepfakes.

MASS-MAIL MAYHEM

How the rise in commodity phishing attacks is overwhelming security teams.

Commodity attacks - mass-produced, malicious campaigns that usually mimic spam by impersonating brands on a large scale - are on the rise. At first glance, these may appear unsophisticated, often using a single image linked to a malicious domain. However, their effectiveness stems from their sheer volume and the polymorphic tactics used across a single campaign, with employees and security admins overwhelmed with the number of attacks landing in inboxes.

The popularity of commodity attacks has fluctuated during the year, peaking in December 2023 at 13.6% of all phishing emails detected by Egress Defend. Our Threat Intelligence team anticipates a similar spike in 2024, as cybercriminals often exploit consumers' familiarity with the rise in legitimate advertising and brand emails during the festive season.

Modeling data from the Egress platform reveals that during a commodity attack campaign, on average organizations experience 2,700% increase versus their normal baseline for phishing attacks.

OVER 31 DAYS, AN ORGANIZATION WITH 2,000 EMPLOYEES WILL RECEIVE:

7382 PHISHING EMAILS OVERALL

WHICH EQUATES TO:

238
PHISHING
EMAILS PER DAY

31.75 attacks p/h
DURING A 7-HOUR
WORKDAY

**Commodity attacks can
mask more targeted
and dangerous phishing
attacks, making them
harder to spot.**

For comparison, the same organization would normally expect to encounter an average of 1.3 phishing attacks daily over a month.

Our analysts suspect that cybercriminals intend to exploit the surge in commodity attacks by using them as white noise to disguise more sophisticated phishing attempts. This tactic not only increases the likelihood of success by overwhelming admins, but also could mask the more targeted and dangerous attacks, making them harder to spot amid the flood of less advanced threats.

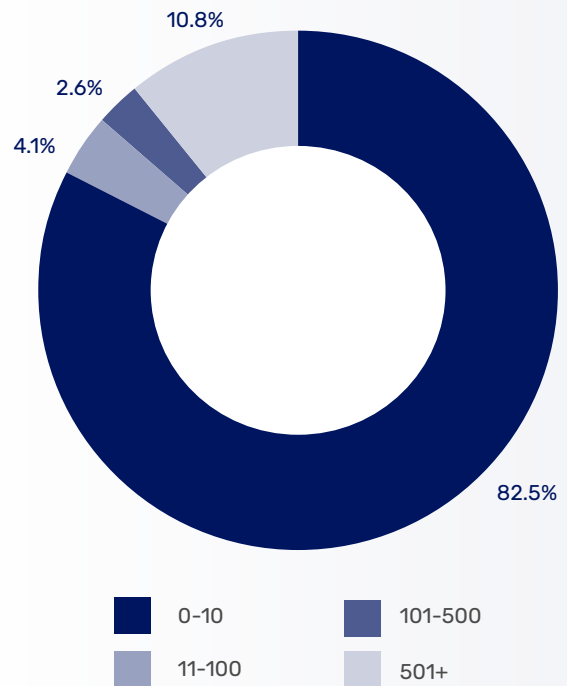
Given the rise in these attacks and the fact that our analysts have observed them being advertised on the dark web, our Threat Intelligence team predicts that these attacks will become even more prevalent in the future.

How commodity attacks are sent

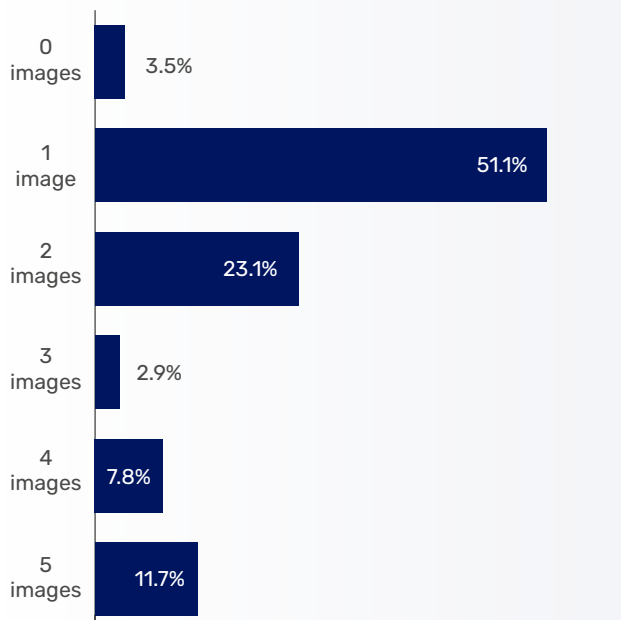
These attacks are primarily image-based, with over half (51.1%) of those analyzed featuring a single graphic as the entire body of the email. Additionally, 82.5% contained only 0-10 characters, with many or all of these likely attributable to static banners added by security tools to indicate that the email is from an unfamiliar or external sender. This renders natural language processing (NLP) ineffective, as it is unable to scan the text for a malicious payload.

Our analysts observed that 86.5% of these attacks originated from 'onmicrosoft.com' domains, with randomized local parts of the email addresses. By using a legitimate Microsoft domain, the emails passed basic authentication checks relied on by traditional detection technologies.

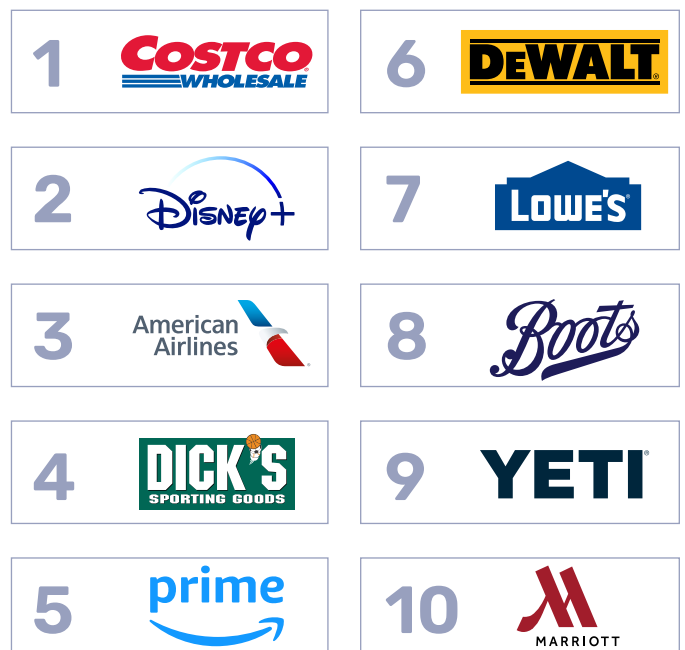
THE AVERAGE CHARACTER COUNT IN A COMMODITY ATTACK



THE NUMBER OF IMAGES IN THE EMAIL BODY OF COMMODITY ATTACKS



THE TOP 10 IMPERSONATED BRANDS IN COMMODITY ATTACKS

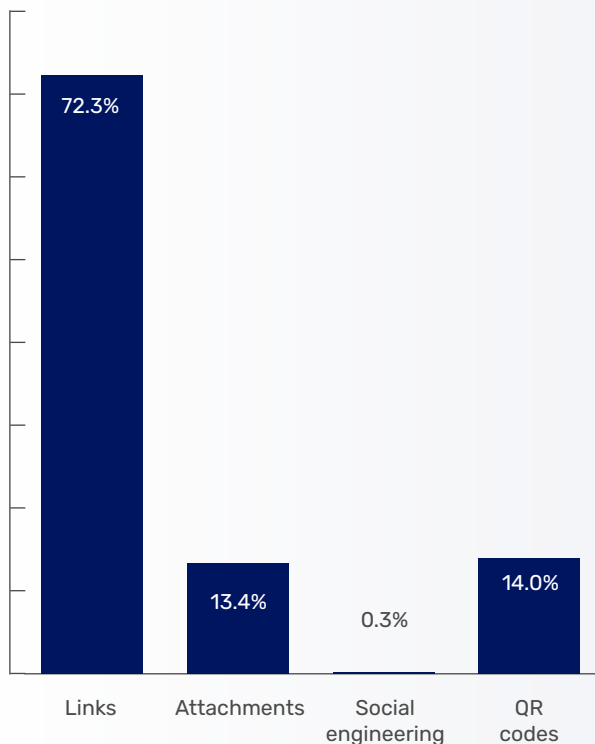


Payloads and obfuscation tactics

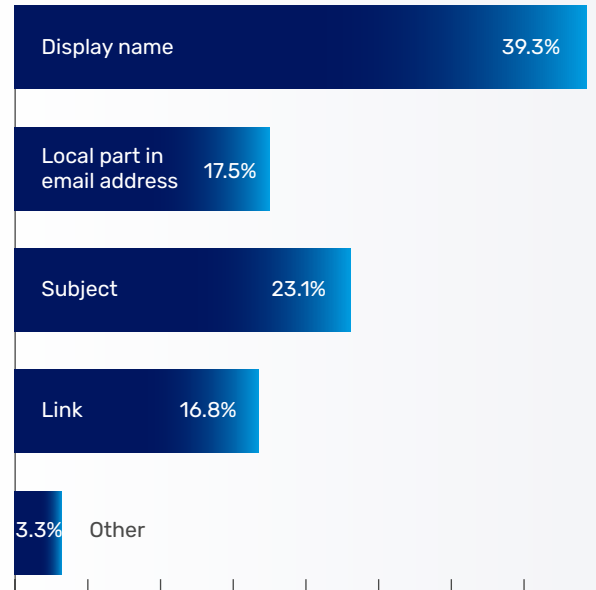
Between August 1st, 2023, and August 31st, 2024, hyperlinks were the most common payload in commodity campaigns, present in 72.3% of attacks.

One trend our analysts identified was hosting malicious links on Amazon Web Services' S3 cloud storage platform, allowing cybercriminals to easily randomize new links. This polymorphic nature makes mass remediation difficult for admins, as cybercriminals can quickly spin up new domains whenever one is blocked. Typically, these malicious links involve an average of three redirects before reaching their end destination.

PAYLOADS USED IN COMMODITY ATTACKS



PRIMARY OBFUSCATION TECHNIQUES USED IN COMMODITY ATTACKS



By using a trusted service like Amazon, the links not only benefit from reduced scrutiny from recipients due to the brand's familiarity but would also pass various checks performed by traditional detection technologies, such as domain age.

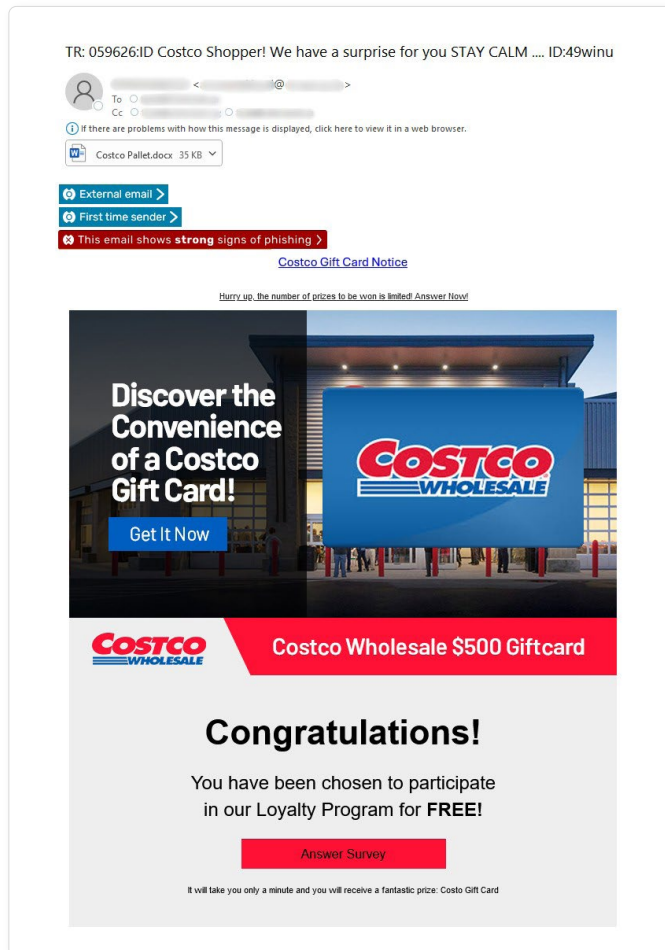
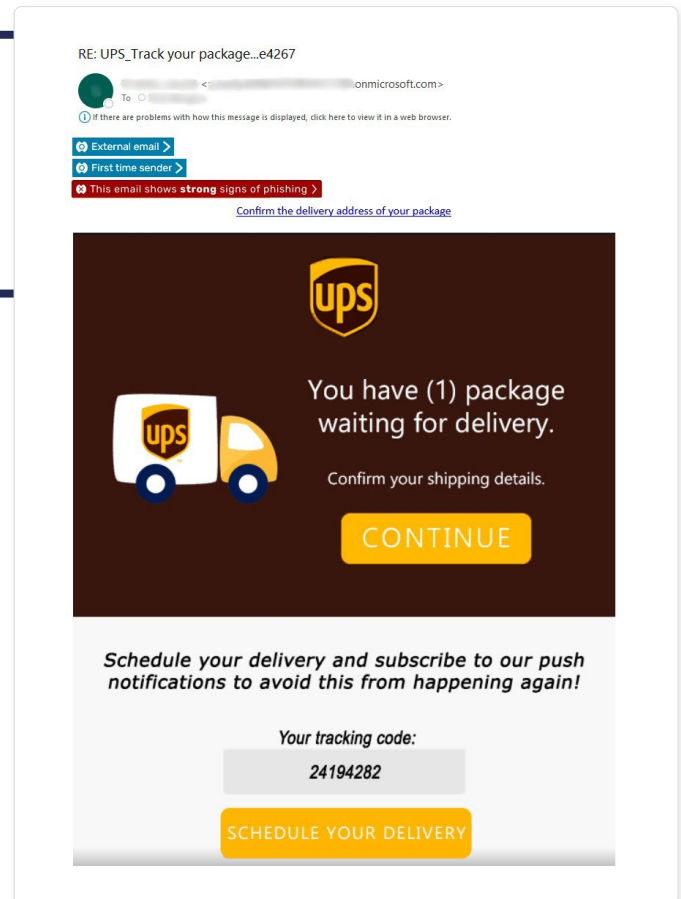
Nearly every attack analyzed was polymorphic in nature, with cybercriminals randomizing elements such as links, display names, or subjects. Additionally, 78.5% of these attacks layered two or more obfuscation techniques. The combination of these techniques makes it significantly more difficult for admins to remediate attacks and block future ones with traditional technology.

What these commodity attacks look like

We've included two examples of commodity attacks from June – August 2024. These attacks would have been sent in bulk to multiple recipients. Both phishing emails were detected by Egress Defend, with its dynamic banners delivering real-time teachable moments.

ATTACK ONE: UPS BRANDING USED TO DELIVER MALICIOUS PAYLOAD

The email was sent from a randomized 'onmicrosoft.com' domain and consisted of a single image that links to a malicious domain.



ATTACK TWO: COSTCO IMPERSONATION EXPLOITS LOYALTY PROGRAM

Again, the body of the email has been made up of an image that links to a malicious domain, but there is also a payload contained in the attachment.

Given the surge in commodity attacks, organizations need intelligent and adaptive security tools that can detect both commodity attacks and any advanced threats using them as cover, as well as automatically adjust policies in real-time based on the emerging threats employees are targeted with. This approach not only eases the burden on security teams but also strengthens employee awareness and understanding of the threats they face.

PLAYING THE LONG GAME

The anatomy of advanced persistent threats and how cybercriminals failed to breach one organization.

Advanced persistent threats (APTs) are outcome driven. Cybercriminals carry out highly targeted, sophisticated, and sustained campaigns against a specific organization to achieve a desired goal – whether that's data exfiltration, extortion, or espionage.

While the ultimate targets of these campaigns are typically large enterprises, their smaller suppliers are often caught in the crosshairs. This enables the cybercriminal to access any data stored locally or, more often, launch onward attacks using a trusted domain.

APTs have significant backing, either state sponsored or by large cybercriminal gangs, and consequently have the resource to develop and deploy new payloads and the patience to carry out multi-step campaigns. Of the 84 APTs we studied for this edition, at least half (52.5%) were classified as zero-day attacks, while only one-third (35.4%) contained previously identified payloads.

Advanced persistent threat 101



Target specific

As APTs are outcome-driven, they focus on a single target and a specific goal once that target has been compromised.



Highly advanced attacks

Most APTs feature zero-day payloads, as well as advanced technical and social engineering tactics.



Multi-stage and multi-channel campaign

Cybercriminals will attack in stages across different channels and using different tactics. They will often include white noise attacks as a disguise.



Infiltrate and expand

Once the target organization has been breached, a cybercriminal will move laterally across the network to achieve their desired outcome.



Heavily resourced

APTs are state sponsored or conducted by large cybercriminal gangs, with the resource available to run slow and methodical campaigns.



Targeted at the supply chain

If the ultimate target has a mature cybersecurity program, attackers will frequently compromise smaller suppliers as a route to their final goal.

Case study: How one organization was targeted by an APT



Real estate



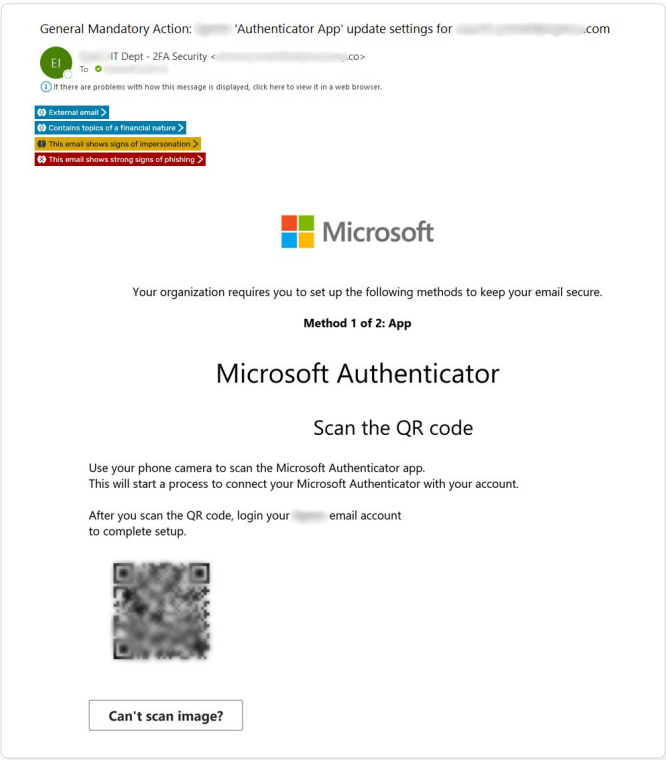
1,200

Day 1 Scouting emails are sent to 17 recipients within the organization. The emails are blank, with no message body or attachments, and are designed to test the organization’s email defenses.

Day 9 Over the course of a Sunday, all 17 original recipients receive second attacks. Two different templates are used: 11 recipients receive an attack impersonating Microsoft, while six receive a Slack impersonation. All attacks contain a phishing hyperlink as the payload.

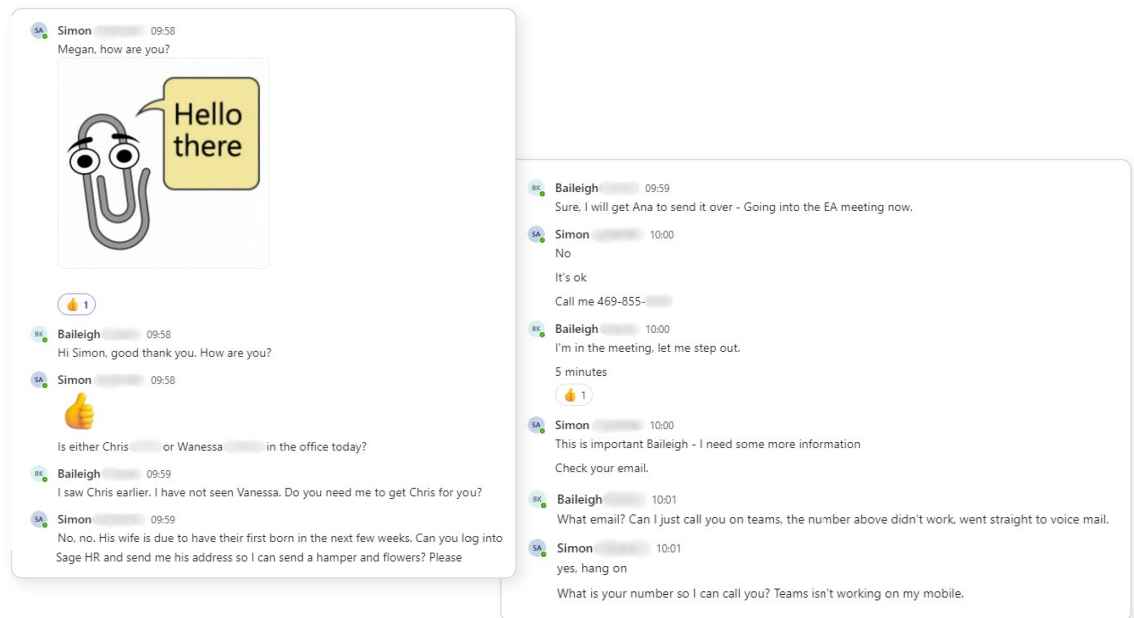
Day 21 Four different phishing campaigns are launched against the 17 targets. Every attack appears to come from a different sender and a combination of different attachment, hyperlink, and QR code payloads are used.

Day 23 Three phishing emails relating to multi-factor authentication (MFA) are sent to the targets. These attacks impersonate Microsoft, Google, and Okta, and are designed to harvest MFA tokens.

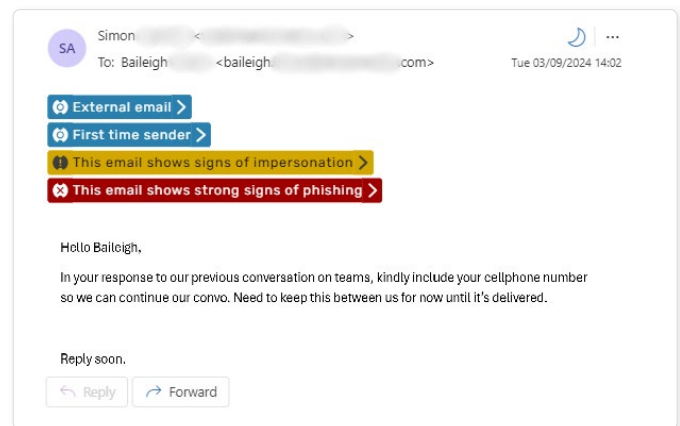


Day 24 A large-scale white noise commodity phishing attack is sent to all 17 recipients throughout the organization. While the attacks contained different phishing hyperlink payloads, they all used similar techniques, tactics, and procedures (TTPs) to the APT campaign.

Day 27 Teams messages impersonating a senior executive are sent to five employees.



Day 34 The same five employees receive phishing emails impersonating the same VIP as the previous Teams messages, referencing these conversations.



Day 35 A Teams calendar invitation is sent to 5 employees. As the company is aware of the APT, their employees don't join the call.

Day 40 As all previous attacks have failed, the cybercriminal sends all 17 employees the same sextortion phishing email in a final attempt to secure a victim.

This APT failed in large part thanks to Egress Defend detecting the phishing emails and the target organization alerting employees about the threat. Key to this defense was detecting emails impersonating brands and senior executives that had bypassed Microsoft 365's native defenses. Read on in the next section to learn more about impersonation-based phishing emails in 2024 and the key functionality needed to detect these attacks.

GUESS WHO?

We look at the most prolific phishing tactic in 2024: impersonation.

As our analysis of commodity phishing campaigns and advanced persistent threats has shown, impersonation is a mainstay tactic across all types of attacks.

Looking at the phishing emails detected by Egress Defend between January 1st and August 31st, 2024, 26.0% appeared to be sent from brands that are not connected to the recipient via an established business relationship. This includes 9.7% impersonating phone or video conferencing providers (such as Zoom) and 5.3% impersonating mail carriers (such as UPS or DPD) as part of established 'missed voicemail' and 'missed delivery' campaigns.

The next most popular attack are ones impersonating the company that the recipient works for, with 16.0% falling into this category. HR was the most impersonated department in these types of attacks, with cybercriminals taking advantage of employees being quick to click on fake benefit packages or similar bait.

PHISHING EMAIL IMPERSONATING HR DEPARTMENT, WITH EGRESS DEFEND ANTI-PHISHING BANNERS APPLIED

IMPORTANT NOTICE: 2024 Reviewed Employee Handbook- All Employees Compliance Required

Human Resources <hrnotice@...>
To: Carolyn ...

Tue 20/08/2024 14:21

This message was sent with High importance.
If there are problems with how this message is displayed, click here to view it in a web browser.

First time sender >

Contains topics of a financial nature >

This email shows strong signs of phishing >

Dear Employee,

Our employee handbook has been updated with new information on benefits, reimbursement for incurred expenses, a code of conduct, and **clear consequences** for serious infractions, like suspension or termination of employment.

Everyone must adhere to our company's standard code of behavior while dealing with customers, suppliers, and contractors, but more crucially when dealing with coworkers

Unlike previously, **EVERYONE** is required to electronically confirm that they have read and agree to these requirements by using the electronic HR compliance area below as soon as they receive this message..

[Review&Submit Acknowledgment](#)

The HR will circle back individually to any **employee that fails to submit acknowledgment** using the above to be sure if such employee does not comply with our policies.

Kindly inform us if you have any questions or concerns.

Regards,
Human Resources.

Social pressure

Sensationalized clickbait topics to generate interest

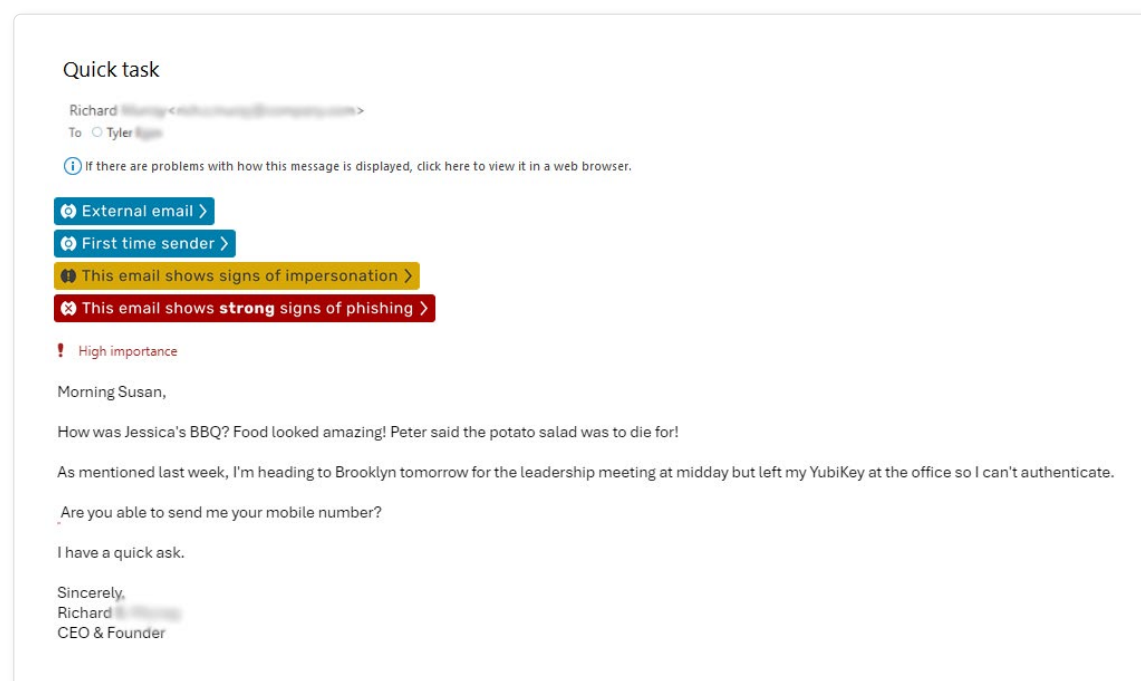
Consequences for inaction

HR is followed by IT and Finance departments that, again, regularly ask people to carry out specific actions related system use and payments. In fact, two of the most impersonated internal systems were e-signatures and employee feedback surveys, and the Microsoft logo appeared in more impersonation attacks than any other (again tied to system use and credential theft, and hijacking legitimate SharePoint links as an obfuscation technique to get through reputation-based detection).

New starters with a tenure of two to seven weeks are the most targeted individuals for phishing emails impersonating VIPs, typically as part of CEO fraud attacks (which impersonate senior executives within the organization). Related to this and the most impersonated departments, the top roles cybercriminals assume are CEO, chief financial officer, and chief people officer.

Cybercriminals don't stop at impersonating employees within an organization – they also assume the celebrities' identities. Like CEO fraud, this is designed to take advantage of the 'authority bias' heuristic, which can cause targets to act more quickly and without questioning instructions. The four famous people most frequently impersonated were: Jeff Bezos, Elon Musk, Warren Buffett, and Mackenzie Scott.

CEO FRAUD ATTACK WITH EGRESS DEFEND ANTI-PHISHING BANNERS VISIBLE



New starters are the most targeted individuals for phishing emails impersonating VIPs, typically as part of CEO fraud attacks.

Tactics and payloads

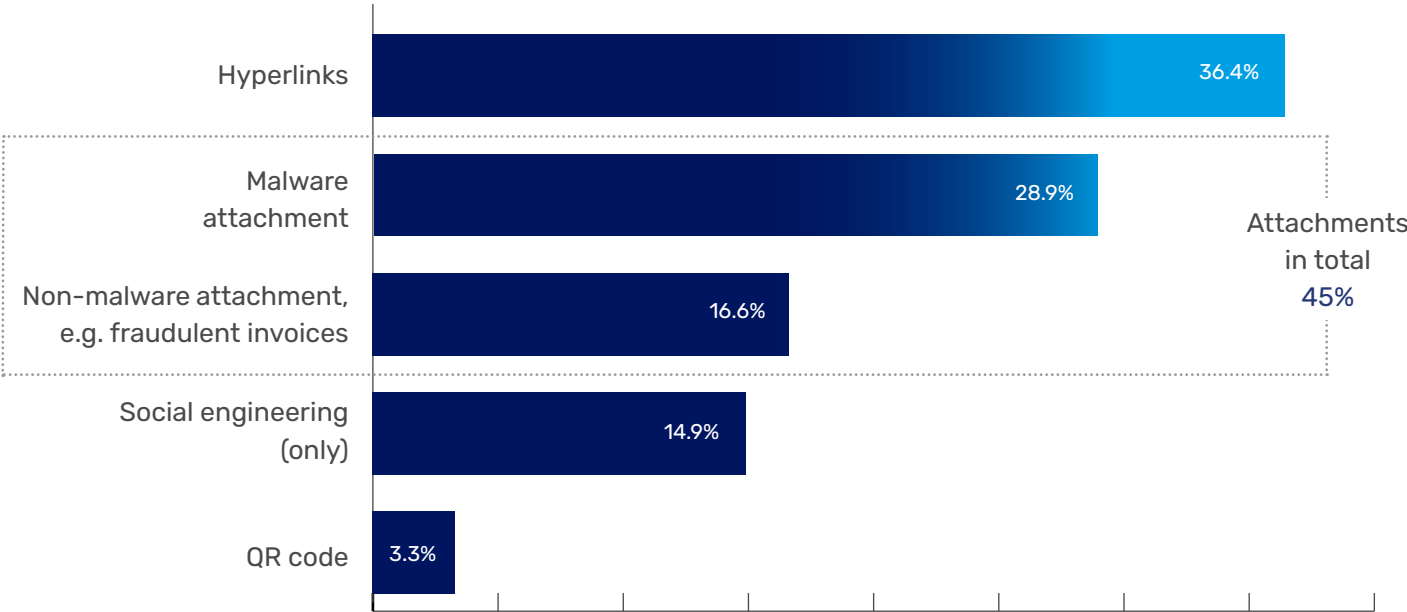
Almost half (45.4%) of the impersonation emails we analyzed had attachments: 28.9% contained traditional malware payloads, while 16.6% either leveraged social engineering (e.g. fraudulent invoices) or obfuscation tactics (e.g. HTML smuggling) to enable them to get through the signature-based detection offered by secure email gateways (SEGs) and Microsoft 365.. A further 14.9% were classed as 'payloadless' and relied solely on social engineering tactics within the email message, again enabling them to get through signature-based detection.

Given the high levels of brand impersonation, it makes sense that using logos and hijacking legitimate hyperlinks are the two most common tactics. The top three hijacked links were docusign.com, sharepoint.com, and dropbox.com.

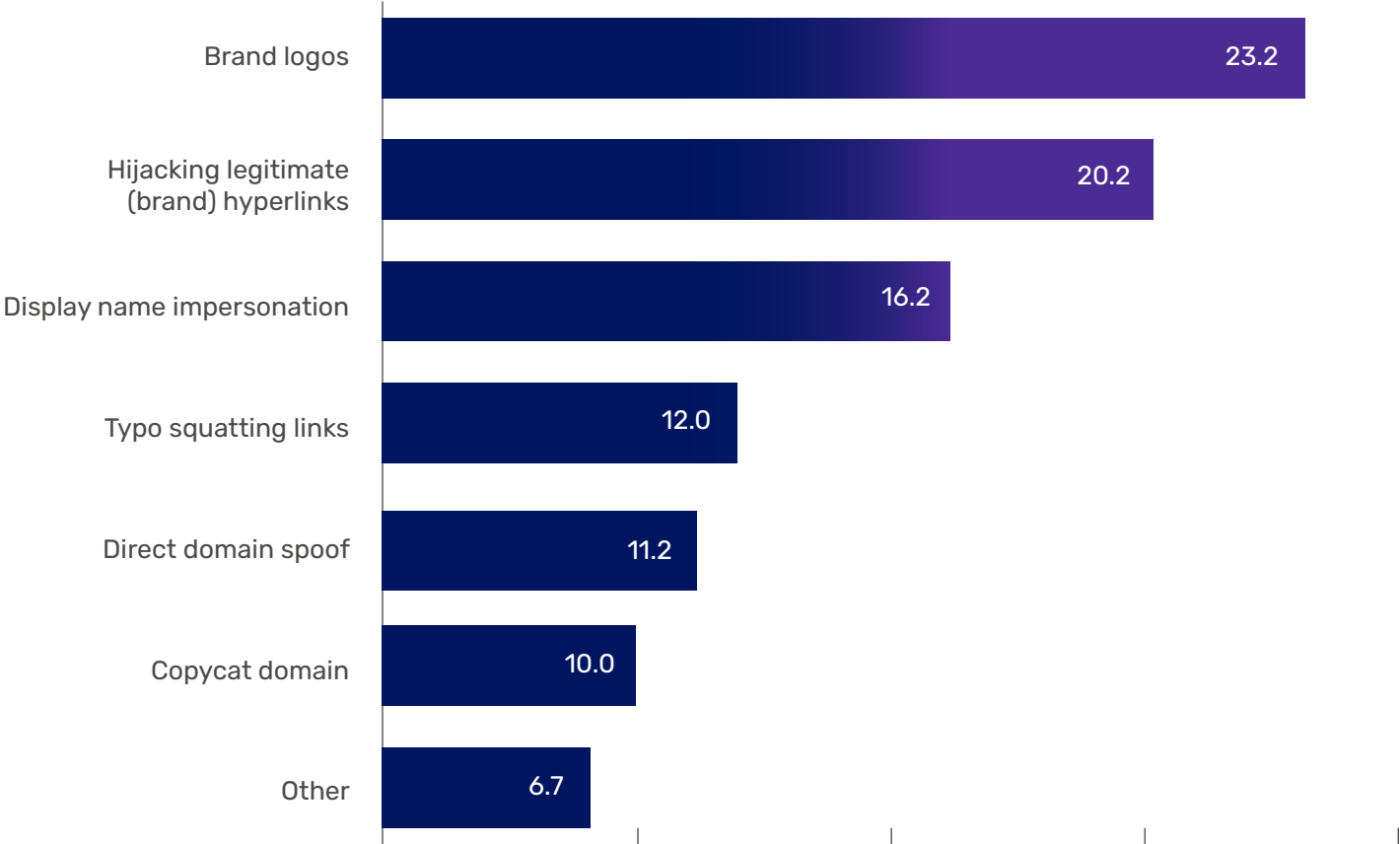
Typo squatting, copycat domains, and direct domain spoofs feature less frequently, however cybercriminals' technical expertise is often rewarded as these advanced techniques make attacks appear more convincing. Lookalike domains closely resembled the original; on average, there were only 1.2 characters different. These domains were also aged for an average of 11 days to help them get through reputation-based detection.

16.6% contained attachments that leveraged social engineering (e.g. fraudulent invoices) or obfuscation techniques (such as HTML smuggling) to enable the attacks to get through signature-based detection.

THE PAYLOADS USED IN IMPERSONATION ATTACKS DETECTED BY EGRESS DEFEND
BETWEEN JANUARY 1ST – AUGUST 31ST, 2024



THE TACTICS USED IN IMPERSONATION ATTACKS DETECTED BY EGRESS DEFEND
BETWEEN JANUARY 1ST – AUGUST 31ST, 2024



Unmasking impersonation attacks

The increasingly sophisticated tactics used in impersonation attacks means they more easily get through the signature-based and reputation-based detection used by Microsoft 365's native security and SEGs. When layering a behavioral-based email security solution in to detect and prevent these attacks, it's important that the following key capabilities are met:



Natural language processing (NLP) to detect linguistic identifiers of social engineering (such as urgent language)



Natural language understanding (NLU) to identify the organizational context behind the being words used (for example, to detect CEO fraud)



The ability to neutralize any obfuscation techniques implemented to prevent NLP and NLU working correctly



Sender display name and email address analysis (including within the email header)



Sender domain analysis (e.g. through authentication protocols and domain age)



Analysis of the organization's own accepted domains, internal systems, and brand



Behavioral analytics for employee email usage



CISO Strategy Guide to Impersonation attacks

Learn more about how cybercriminals design impersonation attacks to get through Microsoft and SEGs, and socially engineering their targets. Plus, the technology needed to detect them.



RIDING THE WAVE OF A NEW AGE OF PHISHING THREATS

As AI is increasingly commoditized and attacks become more difficult to detect, we find ourselves at a turning point.

The commoditization of AI is good news for both cybercriminals and cybersecurity professionals. The key to getting ahead of these AI-powered attacks is making sure that we implement the right AI in our defenses.

In March, a report by Microsoft and Goldsmith's University found that while 87% of organizations are vulnerable to cyberattacks in the age of AI, only 27% are using AI in their defenses. The same research found that organizations using AI-driven defenses are twice as resilient to cyberattacks and suffer 20% fewer costs when successfully attacked thanks to enhanced detection and response.

As our analysis of dark web phishing toolkits has shown, cybercriminals are embracing AI with both hands - and it's incredibly likely that the commodity attacks, advanced persistent threats, and impersonation tactics we've also analyzed in this edition will increasingly get through Microsoft's native security and secure email gateways (SEGs). The good news, however, is that AI defenses are also evolving at pace.

This is a critical junction for every organization. Cybersecurity teams must build a strong foundation of AI-driven defenses that can automate detection and response to a broader spectrum of advanced threats and personalize security, so each employee receives protection that's tailored to the threats they face. A word of caution, however: AI shouldn't be implemented for the sake of it and it's imperative that it doesn't introduce new vulnerabilities.

If you would like to discuss how Egress uses AI to detect advanced phishing attacks and data loss, as well as automate personalized security training, please do get in touch with the team.

We look forward to speaking with you soon.

ABOUT EGRESS DEFEND

An integrated cloud email security solution, Defend delivers AI-powered behavioral-based detection to eliminate the attacks that get through Microsoft 365's native security and secure email gateways. Leveraging zero-trust and pre-generative models, Defend provides the highest efficacy of detection against advanced threats, including zero-day and emerging attacks, phishing emails sent from compromised accounts, and social engineering. Using dynamic banners applied to neutralized threats, Defend provides real-time teachable moments that continually 'nudge' employees into good security behaviors to tangibly reduce risk and augment security awareness.

About Northdoor

Northdoor helps organisations harness the full power of their data throughout its lifecycle. Northdoor helps clients manage all aspects of data—keeping it organised, governed, protected, compliant, accessible by both people and applications, and always ready for high-speed analysis. Northdoor provide solutions across consultancy, applications, security, hybrid infrastructure, analytics, AI, and managed services. Northdoor partners with the biggest and best vendors in global IT, and maintains deep technical skills to help clients overcome any challenges.

About Egress

As advanced persistent threats continue to evolve, we recognize that people are the biggest risk to organizations' security and are most vulnerable when using email.

Egress, a KnowBe4 company, is the only cloud email security provider to continuously assess human risk and dynamically adapt policy controls, preparing customers to defend against advanced phishing attacks and outbound data breaches before they happen. Leveraging contextual machine learning and neural networks, with seamless integration using cloud-native API architecture, Egress provides enhanced email protection, deep visibility into human risk, and instant time to value.

www.egress.com

